

Agentic Stability Framework

ASF Specification and Whitepaper v1.0 - Initial Public Release

A force-based enterprise architecture framework for governing autonomous AI systems

Publication status: Initial Public Release. Released openly for practitioner adoption, field feedback, and future versioned improvements.

© 2026 Sumir Arora. Licensed under Creative Commons Attribution 4.0 International (CC BY 4.0).

Suggested citation: Arora, Sumir. Agentic Stability Framework: A Force-Based Enterprise Architecture Framework for Autonomous AI Systems. v1.0 Initial Public Release, 2026.

Core Thesis

Agentic maturity is not the ability to increase autonomy. Agentic maturity is the ability to increase autonomy while maintaining stability.

Stability Margin Index (SMI) = Enterprise Gravity Index (EGI) - Agentic Force Index (AFI)

Field	Value
Version	v1.0 Initial Public Release
Audience	CIO, CISO, CTO, enterprise architects, platform teams, AI governance boards
Scope	Agentic-system-level stability assessment for autonomous and semi-autonomous AI systems
Status	Initial public release; feedback and field validation welcome for future versions.

Contents

- 1. Executive Summary
- 2. Introduction: Autonomy Is Outpacing Governance
- 3. What ASF Is and Is Not
- 3.1 Assessment Unit: Agentic System Instance
- 4. Related Work and ASF Differentiation
- 5. Core Model: AFI, EGI, SMI
- 6. Force and Gravity Metaphor
- 7. Laws, Axioms, and Vocabulary
- 8. Assessment Methodology
- 9. Basic and Advanced Scoring
- 10. Evidence Tiers
- 11. Threat-Modeling Gate
- 12. Agent Bill of Materials
- 13. Orbit Classification and Deployment Gates
- 14. Reference Architecture
- 15. Patterns and Anti-Patterns
- 16. Domain Overlays
- 17. Worked Examples
- 18. Misuse, Limitations, and Threats to Validity
- 19. Standards Alignment
- 20. Implementation Roadmap
- 21. Conclusion
- Appendix A. AFI Rubric
- Appendix B. EGI Rubric
- Appendix C. Architecture Review Packet
- Appendix D. References

1. Executive Summary

Enterprises are moving from assistive AI to agentic AI. Assistive systems generate information. Agentic systems can reason, plan, call tools, access memory, coordinate with other agents, and act on enterprise systems.

This shift changes the architecture question. It is no longer enough to ask whether an AI output is accurate. The more important question is whether the enterprise can govern what the AI system is allowed to do.

The Agentic Stability Framework (ASF) provides an agentic-system-level model for assessing whether autonomous capability is proportional to enterprise control strength. ASF does not claim to prove that an agent is safe. It indicates whether the governance environment is strong enough to justify the agent's current or proposed level of autonomy.

Primary Definition

ASF is an enterprise architecture assessment model for determining whether the governance environment around an autonomous AI agent is strong enough to contain the operational force created by that agent in a specific business context.

ASF Index	Purpose	Question Answered
Agentic Force Index (AFI)	Measures operational pressure created by autonomy.	How much force does this agent create?
Enterprise Gravity Index (EGI)	Measures governance and control strength around the agent.	How much control exists around this agent?
Stability Margin Index (SMI)	Compares gravity against force.	Is governance proportional to autonomy?



ASF v1.0 treats SMI as a directional architecture indicator, not a proof of safety.

Figure 1. ASF v1.0 core model.

2. Introduction: Autonomy Is Outpacing Governance

The first wave of enterprise generative AI was mostly assistive: summarization, drafting, search, code suggestions, and knowledge access. These capabilities introduced important concerns around accuracy, privacy, security, and responsible use, but the primary output was usually informational.

The next wave is agentic. Agents can interpret goals, create plans, select tools, call APIs, retrieve enterprise context, maintain memory, collaborate with other agents, and trigger real business or technology actions.

This creates action risk. A chatbot that gives a wrong answer creates a quality problem. An agent that deploys the wrong workload, grants the wrong access, updates the wrong customer record, invokes the wrong API, or triggers the wrong financial workflow creates an operational stability problem.

The central enterprise challenge is that agent capability can expand quickly while governance often expands slowly. Adding a new tool, memory store, API, MCP server, CI/CD action, or approval delegation may seem incremental. Collectively, these changes can push autonomy beyond the enterprise's ability to observe, constrain, audit, and recover.

Negative SMI = Agentic Force exceeds Enterprise Gravity

Governance Debt
A negative stability margin should be treated as governance debt: autonomy has been introduced faster than the enterprise control environment can safely contain it.

3. What ASF Is and Is Not

ASF Is	ASF Is Not
An enterprise architecture framework for agentic AI.	A replacement for NIST AI RMF, ISO/IEC 42001, OWASP, or Zero Trust.
An agentic-system-level stability assessment model.	A complete security threat model.
A method for comparing autonomous capability against governance strength.	A regulatory compliance certification.

ASF Is	ASF Is Not
A practical way to identify governance debt and required control uplift.	A mathematical proof of agent safety.
A complement to AI risk, security, compliance, and management-system frameworks.	A vendor-specific architecture or product pattern.
A decision-support model for autonomy expansion.	A maturity score for the entire enterprise.
An assessment of the agentic system instance: model, runtime, memory, tools, identity, permissions, policies, and operating context.	A standalone model benchmark or isolated prompt evaluation.
Agent-centered, but not agent-only; it requires tool, MCP, memory, identity, and context inventory through the ABOM.	A tool-only or MCP-server-only risk classification.

Important Limitation

ASF should not be used to prove that an agent is safe. It should be used to determine whether the enterprise has enough governance strength to justify the agent's current or proposed level of autonomy.

3.1 Assessment Unit: Agentic System Instance

ASF does not assess an isolated model, standalone prompt, or individual tool in isolation. ASF assesses an agentic system instance: the deployed configuration through which autonomous or semi-autonomous reasoning becomes enterprise action.

An agentic system instance includes the model, instructions and prompts, runtime or orchestrator, memory, tools and MCP servers, APIs and plugins, data sources, identity, permissions, policy controls, approval model, deployment environment, and operating context.

For readability, this paper often uses the term agent. Within ASF, agent should be understood as shorthand for the full agentic system instance.

This distinction matters because Agentic Force does not come from the model alone. Force emerges from the combination of decision autonomy, available tools, accessible context, memory, permissions, delegated authority, and operating environment.

Tools and MCP servers should be governed capabilities in their own right, but their operational impact depends on which agentic system can invoke them, under what authority, in which context, and through which controls.

ASF is therefore agent-centered, but not agent-only. It evaluates the full decision-action system.

4. Related Work and ASF Differentiation

ASF does not claim to invent autonomy-proportional governance. The field is converging on the idea that AI-agent autonomy should be earned, bounded, evidenced, and matched with proportional oversight. ASF builds on that direction and contributes an operational enterprise-architecture method for applying it agentic system by agentic system.

Neighboring Work	Primary Focus	How ASF Differs
OWASP Top 10 for Agentic Applications 2026	Security risks in autonomous and agentic systems that plan, act, and make decisions across workflows.	ASF uses agentic security guidance as input, but focuses on architecture stability: whether governance strength is proportional to agentic force.
Singapore Model AI Governance Framework for Agentic AI	Responsible deployment of agents through bounded powers, accountability, human oversight, lifecycle controls, and technical safeguards.	ASF operationalizes proportional oversight through AFI, EGI, SMI, evidence tiers, deployment gates, and review packets.
Pre-deployment assurance research for enterprise AI agents	Operational envelopes, scenario-based verification, trust certificates, and deployment verdicts such as Approved, Conditional, and Rejected.	ASF complements assurance methods with a governance-capacity model and per-agent, per-context architecture review discipline.
Zero Trust and policy-as-code	Continuous verification, least privilege,	ASF extends these concepts to agent

Neighboring Work approaches	Primary Focus	How ASF Differs
	policy enforcement, and access decisions.	identity, tool calls, memory, context retrieval, runtime plans, and autonomous actions.

The honest contribution of ASF is therefore narrow but useful: it packages autonomy-proportional governance into a repeatable assessment method that measures two sides of the equation - the operational pressure created by the agent and the governance gravity available to contain it.

ASF should be read as a practical operating model for enterprise architects, not as a replacement for AI governance, agentic security guidance, or formal assurance research.

5. Core Model: AFI, EGI, SMI

ASF evaluates each agentic system instance in a defined operating context. It does not assign one maturity level to the whole enterprise because different agentic systems create different forces and operate under different controls.

The assessment unit is one agentic system instance: one agentic configuration, in one business context, with a defined set of users, tools, MCP servers, permissions, data sources, memory capabilities, runtime controls, and deployment environments.

5.1 Agentic Force Index

AFI measures the operational pressure created by the agentic system as deployed, including its autonomy, tools, memory, permissions, identity delegation, and operating context. It is not inherently good or bad. It is a measurement of force created by the deployed decision-action capability.

AFI Dimension	Measures
Decision Autonomy	How independently the agent can decide and act.
Decision Velocity	How frequently the agent makes or triggers decisions.
Operational Reach	How broadly the agent can affect systems, domains, or external parties.
Operational Criticality	How severe the impact could be if the agent acts incorrectly.
Adaptability	Whether the agent can dynamically change plans, strategies, or tools.
Collaboration Complexity	Whether the agent coordinates with humans, other agents, or multi-agent workflows.
Persistence and Memory	How long the agent persists and whether it maintains reusable memory.

ASF deliberately includes Operational Criticality inside the Agentic Force Index because consequence severity raises the required governance threshold directly. An agent that can affect high-criticality systems creates more enterprise pressure than an agent with the same autonomy operating in a low-impact context.

5.2 Enterprise Gravity Index

EGI measures the enterprise's ability to observe, constrain, govern, and recover from the full agentic system instance, including controls over tools, MCP servers, memory, identity, policy, and action execution. In v1.0, EGI is tied to evidence tiers so high scores require implementation proof.

EGI Dimension	Measures
Identity	Whether the agent has distinct, verifiable, attributable identity.
Authorization	Whether permissions are scoped, contextual, and enforced.
Policy Enforcement	Whether rules are technically enforced before actions take effect.
Observability	Whether decision provenance can be reconstructed.
Governance and Lifecycle	Whether agents, tools, models, memory, and policies are managed as assets.
Recovery and Resilience	Whether agent behavior can be stopped, reversed, contained, or

EGI Dimension	Measures
Assurance and Evaluation	recovered. Whether behavior is tested, monitored, red-teamed, and evaluated at runtime.

5.3 Stability Margin Index

$$SMI = EGI - AFI$$

SMI is a normalized architecture indicator representing the margin between measured governance capability and measured agentic force. It is not a probability of failure, compliance score, or complete residual-risk calculation.

6. Force and Gravity Metaphor

ASF uses centrifugal force as a metaphor for organizational pressure, not as literal physics. In the metaphor, the enterprise control plane is the center: identity, authorization, policy, audit, approved tools, approved data, recovery mechanisms, and accountable ownership.

As agents gain autonomy, action speed, tool access, memory, and cross-domain reach, they create outward pressure on that control plane. Enterprise Gravity is the set of controls that keeps agent behavior in a stable operating boundary.

The goal is not to eliminate force. The goal is to design enough gravity to sustain useful autonomy.

Metaphor Boundary

The metaphor is intended to make the architecture problem memorable. The ASF scoring model is an enterprise assessment model, not a physics equation.

7. Laws, Axioms, and Vocabulary

7.1 Three Laws of Agentic Stability

1. Autonomy generates force: every increase in agent autonomy generates an increase in organizational force.
2. Stability requires proportional gravity: enterprise stability depends on governance increasing at least as fast as agentic capability.
3. Autonomy must not exceed containment: an agent should not operate beyond the enterprise's ability to observe, constrain, audit, and recover from its behavior.

7.2 Four Axioms

1. Agents are decision systems, not merely applications.
2. Every autonomous action has a blast radius.
3. Governance must become runtime-aware.
4. Stability is agent-specific and context-specific.

7.3 Core Vocabulary

Term	Definition
Agent	Readable shorthand for the full agentic system instance

Term	Definition
	unless explicitly stated otherwise.
Agentic Force	Operational pressure created by an agent's autonomy, velocity, reach, criticality, adaptability, collaboration, and memory.
Enterprise Gravity	The organization's ability to observe, constrain, authorize, audit, govern, recover, and assure agent behavior.
Orbit	The stability classification of an agent based on SMI.
Governance Debt	The gap created when Agentic Force exceeds Enterprise Gravity.
Control Uplift	Actions required to increase Enterprise Gravity or reduce Agentic Force.
Agentic System Instance	The deployed configuration through which reasoning becomes action: model, prompts, runtime, memory, tools, MCP servers, data sources, identity, permissions, policies, approval model, and operating context.

8. Assessment Methodology

ASF assessment follows a structured workflow. The output is an agent-level stability profile, not a generic enterprise maturity label.

Step	Assessment Activity	Output
1	Identify the agent and owner.	Agent profile.
2	Define operating context, tools, data sources, users, memory, and environment.	Operating context.
3	Create the Agent Bill of Materials.	ABOM.
4	Score Agentic Force.	AFI.
5	Score Enterprise Gravity using evidence tiers.	EGI.
6	Calculate Stability Margin.	SMI.
7	Assign orbit and deployment gate.	Decision recommendation.
8	Perform threat modeling where required.	Threat model and mitigations.
9	Define control uplift or risk acceptance.	Governance action plan.
10	Set reassessment triggers.	Review cadence.

Assessment Unit

One agentic system instance: a deployed agent configuration operating in one defined business context, with known tools, MCP servers, data sources, users, permissions, memory, identity, policies, approval model, runtime controls, and deployment environment.

9. Basic and Advanced Scoring

9.1 Basic Mode

Basic Mode is intended for workshops, first-pass triage, and early governance conversations. All dimensions are equally weighted.

$$AFI = \text{Total Force Score} / 35 \times 100$$

$$EGI = \text{Total Gravity Score} / 35 \times 100$$

$$SMI = EGI - AFI$$

9.2 Advanced Mode

Advanced Mode is intended for production, regulated, high-criticality, or high-autonomy agents. It uses domain-specific weighting.

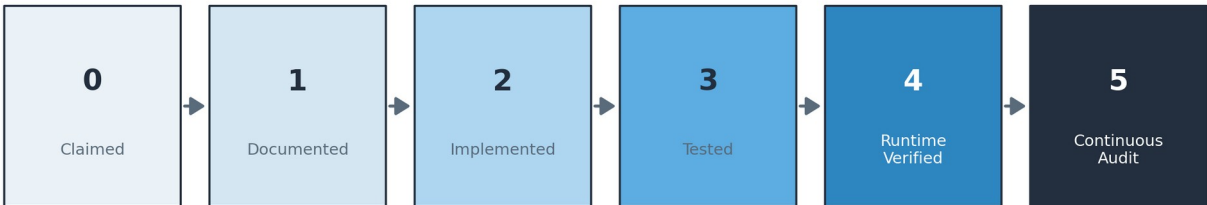
$$\text{Weighted AFI} = \frac{\text{Sum}(\text{Force Score} \times \text{Force Weight})}{\text{Sum}(\text{Max Score} \times \text{Force Weight})} \times 100$$

$$\text{Weighted EGI} = \frac{\text{Sum}(\text{Gravity Score} \times \text{Gravity Weight})}{\text{Sum}(\text{Max Score} \times \text{Gravity Weight})} \times 100$$

Agent Type	Higher AFI Weights	Higher EGI Weights
Deployment Agent	Criticality, Reach, Autonomy	Policy, Recovery, Observability
Customer Service Agent	Reach, Criticality, Memory	Authorization, Assurance, Observability
Security Agent	Autonomy, Criticality, Velocity	Identity, Policy, Recovery
Financial Agent	Criticality, Autonomy, Reach	Authorization, Assurance, Governance
Multi-Agent SDLC Agent	Collaboration, Adaptability, Reach	Observability, Policy, Governance

10. Evidence Tiers

ASF v1.0 requires EGI scores to be evidence-based. A control may exist on paper but fail during runtime. Evidence tiers help distinguish intent from operating effectiveness.



EGI scores above 3 require Tier 3+ evidence. Production-impacting agents require Tier 4 for key controls.

Figure 2. ASF evidence tiers.

Tier	Meaning	Typical Evidence
0	Claimed, no evidence	Verbal statement, slide, or unvalidated design claim.
1	Documented design	Architecture document, policy draft, design decision record.
2	Implemented control	Configured identity, gateway, policy, logging, or workflow.
3	Tested control	Test result, drill, validation evidence, policy test, rollback test.
4	Runtime-verified control	Production trace, policy decision log, runtime monitor, audit event.
5	Continuously monitored and audited control	Dashboards, recurring evidence, automated control checks, periodic audit.

Evidence Rule

No EGI dimension should receive a score above 3 unless the control has Tier 3 or higher evidence. Production-impacting agents require Tier 4 evidence for Policy Enforcement, Observability, Recovery, and Assurance before operating beyond Edge Orbit.

11. Threat-Modeling Gate

ASF is not a complete security threat model. High-force agents require threat modeling before production deployment.

Any agent operating in Edge, Unstable, or Critical Orbit must undergo threat modeling. Threat modeling is also required when the agent has production action authority, sensitive data access, multi-agent handoffs, long-term memory, or external-facing exposure.

Threat Category	Assessment Questions
Prompt injection	Can user or retrieved content override the agent's instructions or policy boundaries?
Tool misuse	Can the agent invoke tools in unintended order, scope, or context?
Excessive agency	Does the agent have broader permissions than its task requires?
Identity abuse	Can agent identity or delegated user authority be misused?
Memory/context poisoning	Can malicious content persist and influence future behavior?
Data exfiltration	Can retrieved or generated content leak sensitive data?
Inter-agent manipulation	Can one agent manipulate another through context, task handoff, or shared memory?
Policy evasion	Can the agent bypass gateway, broker, or policy enforcement points?
Cascading failures	Can one agent action trigger uncontrolled downstream effects?
Recovery failure	Can the enterprise stop, reverse, or contain the action fast enough?

12. Agent Bill of Materials

Every ASF assessment should include an Agent Bill of Materials (ABOM). The ABOM defines the assessment boundary for the agentic system instance. It is the inventory of components and dependencies required to understand what the system is, what it can access, which tools or MCP servers it can invoke, and what it can affect.

ABOM Category	Required Information
Agent	Name, version, owner, purpose, business domain.
Model	Provider, model, deployment mode, approved model status.
Runtime	Agent framework, orchestrator, hosting environment.
Prompts	System prompts, task prompts, prompt versioning and approval.
Tools	APIs, MCP servers, plugins, scripts, functions, workflows; read/write capability, tool risk level, and action reversibility.
Data Sources	Knowledge bases, vector stores, databases, files, SaaS systems.
Memory	Session, short-term, long-term, enterprise memory.
Identity	Agent identity, user delegation, service identity.
Authorization	Permissions, scopes, roles, environments, JIT access, delegated authority, and on-behalf-of model.
Policies	Policy rules, enforcement points, exceptions, tool/action policies, and policy decision logs.
Observability	Logs, traces, audit stores, dashboards, and prompt-plan-

ABOM Category	Required Information
Recovery	tool-action traceability. Rollback, kill switch, circuit breakers, compensating actions, and reversibility limits.
Assurance	Evaluations, red-team tests, runtime monitors, drift checks.
Dependencies	External services, gateways, brokers, registries, MCP servers, and connector dependencies.
System Boundary	Scope of the assessed agentic system instance, including runtime, tools, memory, identity, and deployment context.
Tool / MCP Classification	For each tool or MCP server: data sensitivity, action impact, reversibility, auth model, auditability, and abuse potential.
Action Authority	Whether actions are read-only, draft-only, human-approved, policy-approved, or independently executed.

ABOM Rule

No agentic system should move beyond Controlled Orbit without an Agent Bill of Materials that defines the system boundary and classifies tools, MCP servers, memory, identity, permissions, and action authority.

13. Orbit Classification and Deployment Gates

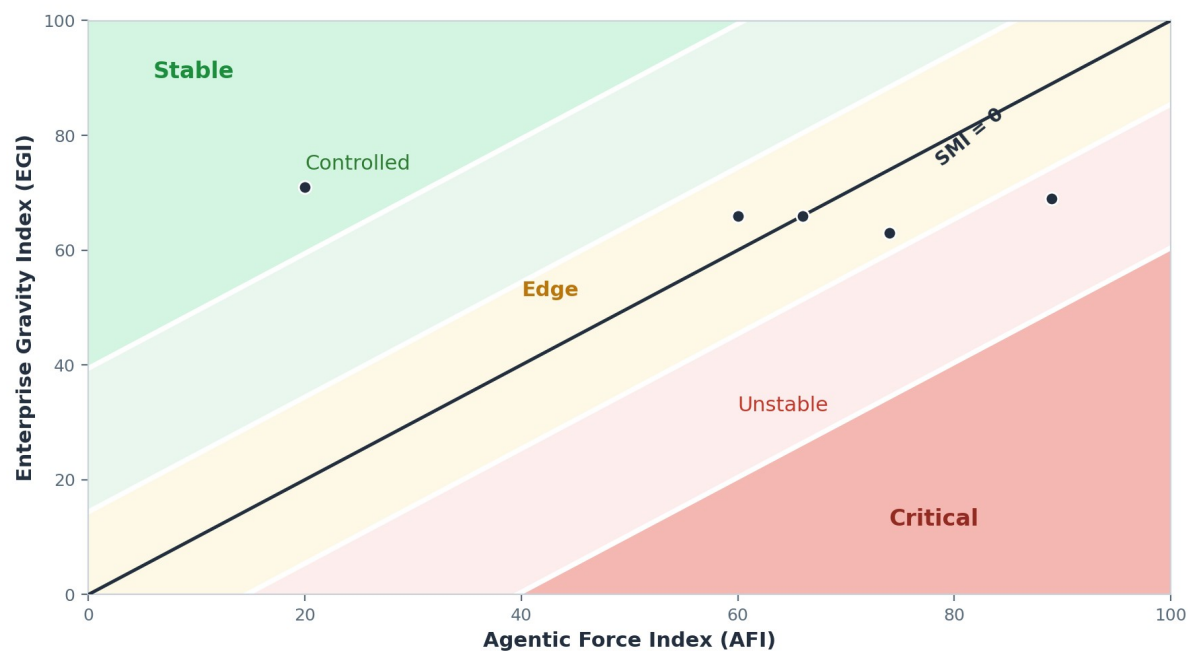


Figure 3. Orbit classification by AFI and EGI.

SMI Range	Orbit	Default Deployment Decision
+40 to +100	Stable Orbit	Approved for scale with monitoring.
+15 to +39	Controlled Orbit	Approved with standard controls.
-14 to +14	Edge Orbit	Pilot, sandbox, or limited production only. Active control management required.
-15 to -39	Unstable Orbit	Do not expand. Control uplift required.
-40 to -100	Critical Orbit	Do not deploy without formal exception.

13.1 Risk Acceptance Workflow

If SMI is negative, the enterprise must choose one of five actions: reduce force, increase gravity, restrict deployment zone, add approval, or formally accept risk with expiration.

Risk Acceptance Field	Requirement
Business Owner	Named accountable owner.
Technology Owner	Named accountable owner.
Reason	Why exception is needed.
Compensating Controls	Controls that reduce exposure.
Expiration Date	No open-ended exceptions.
Reassessment Date	Required follow-up.
Residual Risk	Accepted risk statement.
Approval Record	Governance approval evidence.

14. Reference Architecture

The ASF reference architecture defines how enterprises create enough Enterprise Gravity to safely contain Agentic Force. The architecture is vendor-neutral and focuses on control responsibilities rather than product selection. Figure 4 is a simplified view; the table below enumerates the full set of control layers.

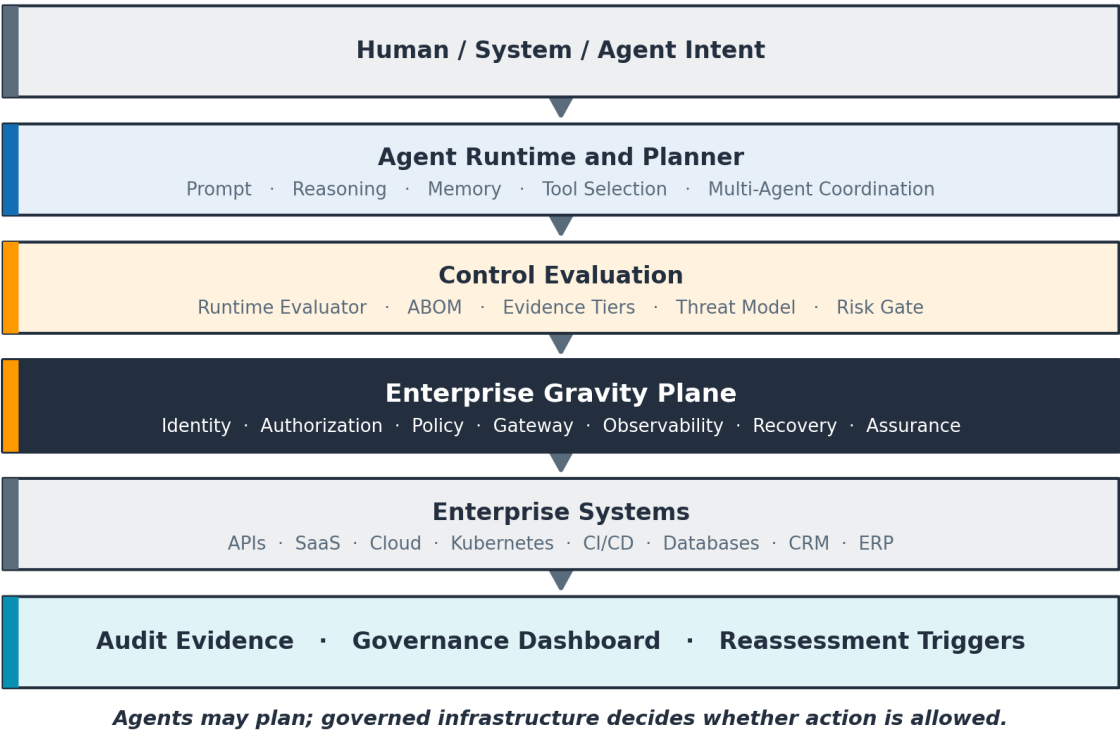


Figure 4. ASF v1.0 reference architecture.

Layer	Purpose	Representative Controls
Agent experience	Receives intent from humans, systems, or agents.	Request identity, authority, intent classification.
Agent runtime and planner	Generates plans and selects tools.	Agent identity, prompt governance, plan traceability.
Context and memory	Provides enterprise knowledge and persistent state.	Data classification, retrieval authorization, memory governance.

Layer	Purpose	Representative Controls
Tool registry and broker	Controls what tools the agent can invoke.	Tool inventory, schema validation, least privilege, action routing.
Policy and gateway	Enforces enterprise rules before action.	PDP/PEP, OPA/Cedar-style policy, API/AI gateway, allowlists.
Runtime evaluation	Evaluates plans, inputs, outputs, and tool behavior.	Prompt-injection checks, drift detection, business-rule validation.
Observability and audit	Reconstructs decisions and outcomes.	Prompt-plan-tool-action traces, SIEM, audit evidence.
Recovery and containment	Stops or reverses unsafe behavior.	Kill switch, rollback, circuit breaker, credential revocation.
Governance dashboard	Maintains portfolio visibility.	Agent catalog, AFI/EGI/SMI, evidence tiers, review dates.

Architecture Rule

Agents may plan, but governed infrastructure decides whether action is allowed.

14.1 Tool and MCP Governance Boundary

A tool or MCP server should be classified for data sensitivity, action impact, reversibility, authorization model, auditability, and abuse potential. However, tool classification alone does not determine stability.

Stability depends on how that tool is exposed to a specific agentic system, under a specific identity, with specific permissions, policies, memory, and approval controls. The same MCP server may be low-force in a read-only assistant and high-force in an autonomous approval or deployment workflow.

15. Patterns and Anti-Patterns

15.1 Recommended Patterns

Pattern	Use When	Minimum Controls
Read-Only Assistant	Agent summarizes or answers from approved sources.	User identity, source authorization, basic logging.
Human-Approved Action	Agent prepares action but human approves.	Agent registry, approval workflow, action preview, tool-call logs.
Policy-Approved Action	Agent executes under strict policy.	Workload identity, broker, runtime policy, rollback.
Multi-Agent Workflow	Several agents coordinate across process.	Agent-to-agent identity, handoff tracing, shared-context governance.
Autonomous Operations	High-autonomy production workflows.	Dynamic authorization, continuous assurance, blast-radius isolation, formal risk governance.

15.2 Anti-Patterns

Anti-Pattern	Why It Is Dangerous
Direct-to-System Agent	Bypasses tool broker, policy, approval, and audit controls.
Shared Credential Agent	Breaks attribution and makes revocation difficult.
Invisible Agent	Exists outside catalog, ownership, reassessment, and risk visibility.
Prompt-Only Governance	Relies on instructions rather than enforceable controls.
Human Rubber Stamp	Creates approval theater without meaningful accountability.
Ungoverned Tool Discovery	Lets the agent invoke unapproved tools and dependencies.

16. Domain Overlays

The base ASF model is generic. Domain overlays adjust weights, evidence expectations, threat scenarios, and control uplift recommendations for specific types of agents.

Overlay	When to Use	Required Emphasis
Software Delivery Agents	Agents reviewing, coding, testing, merging, or deploying software.	Artifact provenance, repo permissions, CI/CD policy, rollback, code review.
Cloud and Infrastructure Agents	Agents provisioning, configuring, or remediating cloud/platform systems.	Least privilege, blast-radius isolation, IaC policy, recovery drills.
Security Operations Agents	Agents triaging alerts, changing controls, or responding to incidents.	Identity, privilege boundaries, auditability, containment.
API Governance Agents	Agents reviewing specs, attaching policies, publishing APIs.	Catalog workflow, policy binding approval, traceability.
Customer Service Agents	Agents accessing CRM, cases, customer data, or external communications.	PII controls, authorization, assurance, human escalation.
Financial Operations Agents	Agents approving payments, invoices, reconciliations, or financial actions.	Segregation of duties, approval evidence, fraud controls.
HR and Workforce Agents	Agents affecting employees, access, payroll, or performance processes.	Sensitive data controls, human accountability, audit.
Regulated-Data Agents	Agents touching health, financial, legal, or regulated datasets.	Data minimization, audit-grade evidence, regulatory review.
Multi-Agent Engineering Workflows	Planner, coder, tester, reviewer, releaser collaboration.	Handoff tracing, role boundaries, conflict resolution, shared memory governance.

17. Worked Examples

Agent	Purpose	AFI	EGI	SMI	Orbit	Decision	Required Uplift
Documentation Assistant	Knowledge answers	20	71	+51	Stable	Scale	Basic source auth and logging.
Client-Request Automation Agent	Client-servicing actions	60	66	+6	Edge	Pilot / limited production	Runtime eval; audit trace; rollback evidence; advisor gates.
Kubernetes Deployment Agent	Deploy workloads	66	66	0	Edge	Limited production	Runtime assurance; namespace auth; rollback evidence.
Multi-Agent SDLC Workflow	Plan/code/test/release handoffs	74	63	-11	Edge	Pilot only	Threat model; handoff tracing; shared-context governance.
Autonomous Remediation Agent	Incident remediation	89	69	-20	Unstable	Do not expand	Tier 4+ evidence; blast-radius isolation; formal exception or uplift.

17.1 Anonymized Client-Request Automation Agent (Financial Services)

This example is drawn from a representative financial-services client-servicing pattern; client, vendor, and identifying architecture details have been generalized. It exercises the full framework and illustrates ASF's central insight: strong enterprise governance does not guarantee a positive stability margin when agentic force is high. The scores below are representative; a live assessment would attach real evidence at the tiers shown.

Agent and operating context: the agent receives client-servicing requests - for example contact-detail updates, document requests, and transfers between a client's own accounts - interprets intent, retrieves client context, and prepares or executes the servicing action through backend APIs. Higher-impact actions require human advisor approval; lower-impact actions execute under policy. The agent acts under delegated, on-behalf-of authority and is fronted by an API gateway, enterprise identity provider, tool broker, and runtime inspection policy at defined control points.

ABOM Category	Anonymized Contents
Agent purpose	Interpret client-servicing requests, retrieve client context, prepare or execute servicing actions, and route high-impact requests for advisor approval.
Runtime	Enterprise agent runtime integrated with a bounded servicing-action catalog, tool broker, API gateway, and client-servicing workflow.
Tools	Servicing APIs with write access, CRM read access, document service, policy/risk classifier, advisor approval workflow, and notification channel.
Data sources	Client CRM and account systems containing regulated PII and financial data; approved servicing policy and procedure sources.
Memory	Session and task memory only; no long-term, cross-client, or self-maintained enterprise memory.
Identity and authorization	Distinct agent identity with on-behalf-of user delegation; tool and environment scopes enforced through gateway and broker controls.
Explicit restrictions	No autonomous high-impact financial action, no cross-client memory, no self-approved exceptions, and no bypass of advisor approval or policy gates.

AFI Dimension	Score	Rationale
Decision Autonomy	3	Executes low-impact actions under policy; high-impact financial or client-impacting actions require explicit advisor approval.
Decision Velocity	3	Event-driven decisions triggered by client-servicing requests.
Operational Reach	3	Touches multiple applications within one business domain, including servicing, CRM, document, and account-related APIs.
Operational Criticality	5	Incorrect action can affect regulated client financial records, account servicing, compliance exposure, and client trust.
Adaptability	3	Generates plans dynamically over retrieved client context, but remains bounded by a defined servicing-action catalog.
Collaboration Complexity	2	Collaborates with advisors and workflow systems; no dynamic multi-agent coordination.
Persistence and Memory	2	Uses short-term task memory only; no long-term or cross-client memory.
Total	21 / 35	AFI = 60

EGI Dimension	Score	Evidence Tier	Evidence Example
Identity	4	3	Distinct agent identity with strong authentication and on-behalf-of delegation; tested evidence required to sustain a 4.
Authorization	4	3	Least privilege by tool and environment, gateway-enforced, with delegated context carried through the request path.
Policy Enforcement	4	4	Runtime enforcement at the gateway with external inspection at defined control points; runtime-verified.
Observability	3	3	Gateway and tool-call logs plus partial prompt, plan, and action traces; not yet full audit-grade end-to-end provenance.
Governance and Lifecycle	3	3	Catalogued with lifecycle approval and reviewed by AI risk, architecture, and change governance.
Recovery and Resilience	3	3	Gateway kill switch and advisor approval gates exist; rollback or compensating control for executed financial actions is only partly tested.
Assurance and Evaluation	2	2	Pre-release scenario testing exists; no continuous runtime evaluation, drift detection, or outcome validation yet.
Total	23 / 35	-	EGI = 66

SMI = 66 - 60 = +6. Orbit classification: Edge Orbit.

Interpretation: the agent is useful and meaningfully governed, but it is still close to the governance boundary because it can touch regulated client data and financial-servicing actions. It can operate in pilot or limited production, but it should not receive broader autonomy until runtime assurance, audit-grade decision provenance, and tested recovery controls improve.

Control Uplift	Reason
Add runtime evaluation for client-servicing decisions	High-impact or ambiguous client requests should be evaluated at runtime before execution or approval routing.
Increase observability to audit-grade decision provenance	Reviewers should reconstruct the initiating user, delegated authority, prompt, retrieved client context, plan, policy result, tool call, approval decision, action, and outcome end to end.
Test rollback and compensating controls	Some financial or client-record actions cannot be simply undone; compensating processes must be tested and evidenced.
Keep advisor approval for high-impact workflows	Human accountability remains necessary for transfers, sensitive data changes, exceptions, and elevated-risk servicing actions until SMI improves.
Require threat modeling before autonomy expansion	The agent touches regulated PII and financial workflows; model prompt injection, tool misuse, delegated-authority abuse, approval bypass, and data-exfiltration paths.

Deployment decision: pilot or limited production only. Keep advisor approval for high-impact actions, retain policy-based controls for lower-impact actions, and do not expand autonomy until the identified control uplifts are implemented and reassessed.

18. Misuse, Limitations, and Threats to Validity

18.1 Misuse Guardrails

- Do not use SMI as the only approval decision.
- Do not claim that a positive SMI proves an agent is safe.
- Do not replace threat modeling, security testing, regulatory review, or business risk assessment with ASF.
- Do not average all agents into a single enterprise maturity score.
- Do not assign high EGI scores based only on design intent.
- Do not treat human approval as sufficient governance by itself.
- Do not let vendors self-certify agent stability without enterprise validation.
- Do not ignore domain-specific risk overlays.

18.2 Limitations and Threats to Validity

ASF is a decision-support framework, not a mathematical proof of agent safety. Its results should guide architecture, governance, and risk discussions, but they should not be treated as automatic approval decisions.

Limitation	Why It Matters	Mitigation
Scoring is judgment-based	Two qualified assessors may score the same agent differently, especially when evidence is incomplete.	Use calibration sessions, scoring examples, review boards, and evidence-tier requirements.
Orbit thresholds are heuristic	The +40, +15, -14, and -40 thresholds are pragmatic starting points, not empirically derived safety boundaries.	Calibrate thresholds over time using incident history, regulatory exposure, risk appetite, and domain experience.
Advanced-mode weights are contextual	Domain overlays reflect expert judgment and may differ by organization or industry.	Document weights, review them periodically, and require governance approval for high-impact overlays.
Positive SMI does not prove safety	A positive margin indicates proportional governance under the model, not guaranteed safe behavior.	Combine ASF with threat modeling, security testing, runtime monitoring, and regulatory review.
ASF depends on evidence quality	Weak or untested evidence can create false confidence in Enterprise Gravity.	Require tested or runtime-verified evidence for high EGI scores and production-impacting agents.
ASF does not replace domain expertise	Healthcare, financial, HR, safety, and regulated workflows require specialized review.	Use ASF alongside domain-specific risk, legal, compliance, clinical, or security disciplines.

19. Standards Alignment

Framework	Primary Purpose	ASF Relationship
NIST AI RMF	AI risk management across lifecycle through Govern, Map, Measure, and Manage.	ASF provides agent-level stability scoring inside broader AI risk management.
ISO/IEC 42001	Requirements and guidance for an AI management system.	ASF provides an architecture assessment method for agentic systems under an AIMS.
OWASP GenAI / Agentic AI	Security threats and mitigations for LLM and agentic systems.	ASF uses OWASP guidance as input to Assurance, Policy, and threat-model gates.
OWASP Multi-Agent Threat Modeling	Threat modeling guidance for systems with multiple coordinating autonomous agents.	ASF requires threat modeling for multi-agent workflows and for Edge, Unstable, or Critical Orbit agents.
Zero Trust	Continuous verification of access to resources.	ASF extends verification to agent identity, delegated authority, tool calls, context, memory, and actions.
OPA / Cedar-style policy	Externalized policy and authorization decisions.	ASF treats policy engines as Enterprise Gravity components.

20. Implementation Roadmap

Phase	Objective	Deliverables
1. Discover	Identify and register active and planned agents.	Agent catalog, owner list, initial ABOMs.
2. Baseline	Run Basic Mode scoring for top agents.	AFI, EGI, SMI, orbit distribution.
3. Govern	Create deployment gates, evidence tiers, and threat-model triggers.	Architecture review packet, risk acceptance workflow.
4. Implement Gravity	Deploy identity, authorization, policy, gateway, observability, recovery, assurance controls.	Reference control plane, dashboard, evidence automation.
5. Automate	Embed ASF into onboarding and CI/CD or agent platform workflows.	Automated metadata validation, policy checks, reassessment triggers.
6. Improve	Use lessons from incidents, red teams, and audits to refine overlays.	v1.1 domain overlays, benchmark library, external review.

21. Conclusion

Agentic AI changes the enterprise architecture problem because agents do not merely generate content; they can take action. Enterprises need a way to determine when autonomy is proportional to control strength.

ASF provides that discipline through Agentic Force, Enterprise Gravity, Stability Margin, Orbit Classification, evidence tiers, threat-model gates, ABOM, and control uplift planning.

The goal is not to slow down agentic adoption. The goal is to make autonomy safe enough to scale.

Increase autonomy only when gravity is strong enough to hold it.

Appendix A. AFI Rubric

Decision Autonomy

Score	Description
0	No decision capability
1	Suggests actions only
2	Recommends actions for human approval
3	Executes after explicit human approval
4	Executes under policy-based approval
5	Executes independently within delegated authority

Decision Velocity

Score	Description
0	No decisions
1	Occasional or manually triggered
2	Daily or batch decisions
3	Hourly or event-driven
4	Near-real-time

Score	Description
5	Continuous autonomous loop

Operational Reach

Score	Description
0	No system access
1	Single user workspace
2	Single application or repository
3	Multiple apps in one domain
4	Multiple domains or business units
5	Enterprise-wide or external ecosystem

Operational Criticality

Score	Description
0	No operational impact
1	Low impact
2	Team productivity impact
3	Application/workflow impact
4	Production/customer/security impact
5	Financial/regulatory/safety/enterprise-critical impact

Adaptability

Score	Description
0	No adaptation
1	Static prompt or fixed workflow
2	Chooses predefined paths
3	Generates plans dynamically
4	Learns from feedback or memory
5	Discovers tools/modifies strategies/self-optimizes

Collaboration Complexity

Score	Description
0	No collaboration
1	Single-agent interaction
2	Human-agent collaboration
3	Multiple agents with fixed roles
4	Dynamic handoffs
5	Swarm-like or emergent behavior

Persistence and Memory

Score	Description
0	No persistence
1	Single-session only
2	Short-term task memory
3	Long-lived scoped memory
4	Cross-session memory
5	Enterprise memory or self-maintained knowledge state

Appendix B. EGI Rubric

Identity

Score	Description
0	No distinct identity
1	Shared user or service account
2	Dedicated service identity
3	Workload identity with ownership metadata
4	Short-lived credentials and strong authentication
5	Cryptographic workload identity with continuous verification

Authorization

Score	Description
0	No authorization boundary
1	Broad static access
2	Role-based access
3	Least privilege by tool/workflow
4	Context-aware authorization
5	Dynamic policy-driven JIT access

Policy Enforcement

Score	Description
0	No policy enforcement
1	Human guidelines only
2	Static configuration checks
3	CI/CD or pre-execution policy checks
4	Runtime policy enforcement
5	Adaptive policy enforcement with risk-based decisions

Observability

Score	Description
0	No logs
1	Basic application logs
2	Tool-call logs
3	Prompt/plan/action/response traces
4	End-to-end traceability
5	Full decision provenance with audit-grade evidence

Governance and Lifecycle

Score	Description
0	No inventory
1	Informal ownership
2	Agent catalog or registry
3	Lifecycle approval workflow
4	Versioning/certification/deprecation controls
5	Enterprise control plane for agents/tools/models/memory/policies

Recovery and Resilience

Score	Description
0	No recovery mechanism

Score	Description
1	Manual intervention only
2	Basic rollback
3	Kill switch or circuit breaker
4	Automated rollback and human takeover
5	Blast-radius isolation and recovery drills

Assurance and Evaluation

Score	Description
0	No evaluation
1	Manual testing before release
2	Basic prompt/output evaluation
3	Scenario evaluation and red team testing
4	Runtime evaluation and drift detection
5	Continuous assurance across policy, behavior, security, and outcomes

Appendix C. Architecture Review Packet

- Agent profile and business context.
- Agent Bill of Materials defining the agentic system boundary.
- AFI, EGI, SMI, and orbit classification.
- Deployment zone and deployment decision.
- Architecture diagram.
- Tool/MCP inventory and data-source inventory, including read/write capability and reversibility.
- Identity, authorization, policy, observability, recovery, and assurance models.
- Threat model and mitigation plan.
- Evidence tier summary.
- Open control gaps and control uplift plan.
- Risk acceptance record if applicable.
- Reassessment date and triggers.

Appendix D. References

- [1] NIST AI Risk Management Framework - AI RMF Core: <https://airc.nist.gov/airmf-resources/airmf/5-sec-core/>
- [2] NIST AI Risk Management Framework overview: <https://www.nist.gov/itl/ai-risk-management-framework>
- [3] ISO/IEC 42001:2023 - AI management systems: <https://www.iso.org/standard/42001>
- [4] ISO - AI management systems: what businesses need to know: <https://www.iso.org/artificial-intelligence/ai-management-systems>
- [5] OWASP Agentic AI - Threats and Mitigations: <https://genai.owasp.org/resource/agentic-ai-threats-and-mitigations/>
- [6] OWASP Multi-Agentic System Threat Modeling Guide v1.0: <https://genai.owasp.org/resource/multi-agentic-system-threat-modeling-guide-v1-0/>
- [7] OWASP AI Agent Security Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html

[8] Open Policy Agent documentation: <https://openpolicyagent.org/docs>

[9] Open Policy Agent - Rego policy language: <https://openpolicyagent.org/docs/policy-language>

[10] OWASP Top 10 for Agentic Applications 2026: <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>

[11] Model AI Governance Framework for Agentic AI (Version 1.0), Infocomm Media Development Authority (IMDA), Singapore, January 2026: <https://www.imda.gov.sg/-/media/imda/files/news-and-events/media-room/media-releases/2026/01/factsheet-model-ai-governance-framework-for-agentic-ai.pdf>

[12] Toward Pre-Deployment Assurance for Enterprise AI Agents: <https://arxiv.org/abs/2606.04037>

[13] Governed AI-Assisted Engineering: Graduated Human Oversight for Agentic Code Generation in Regulated Domains: <https://arxiv.org/abs/2606.22484>